

Literature Review

Unified DevSecOps Telemetry Portal (P030)

1. Introduction

Modern software organizations increasingly rely on Continuous Integration and Continuous Deployment (CI/CD) pipelines to deliver software quickly and reliably. While this automation accelerates delivery, it also introduces new security risks, since vulnerabilities can be pushed to production as fast as code changes are made. DevSecOps has emerged as the dominant response to this challenge, embedding security practices directly into the development and operations lifecycle rather than treating security as a final, separate stage. This literature review examines the current body of research and industry practice on DevSecOps, security testing integration in CI/CD pipelines, the persistent challenges organizations face when adopting these practices, and the design of unified dashboards for vulnerability visualization. The review is structured to build toward the specific problem addressed by the P030 project: the lack of a centralized, real-time view of security and pipeline data at Cyberani by Aramco Digital.

2. The Evolution and Concept of DevSecOps

DevSecOps extends the DevOps philosophy by making security a shared responsibility across development, security, and operations teams, rather than a gate enforced only at the end of the software development lifecycle. Shanmugam and El-Den (2025) conducted a systematic literature review of 36 studies published between 2012 and 2025 and identified automation, continuous security integration, toolchain orchestration, and cultural transformation as the dominant themes shaping the field. Their review also found that despite the maturity of individual tools, organizations continue to struggle with standardizing practices and achieving interoperability between different parts of the security toolchain.

A central principle recurring across the literature is "shift-left" security: moving security testing and validation as early as possible in the development process, rather than performing it only before release. Koneru (2021) frames this shift as a way to detect and remediate vulnerabilities while code is still cheap to change, rather than after it has propagated through the pipeline. This principle directly motivates the architecture proposed for the P030 portal, which is designed to surface security findings from every stage of the pipeline rather than only at deployment.

3. Security Testing Integration in CI/CD Pipelines

A recurring theme across the literature is the combined use of Static Application Security Testing (SAST), Dynamic Application Security Testing (DAST), and Software Composition Analysis (SCA) as complementary layers of automated security testing within CI/CD pipelines. Koneru (2021) demonstrates how these three categories of tooling address different attack surfaces: SAST analyzes source code for insecure patterns before it is even compiled, DAST probes a running application for exploitable behavior, and SCA identifies known vulnerabilities in third-party dependencies. The study reports that integrating all three into a pipeline allows vulnerabilities to be identified and addressed before code reaches production, supporting both security and regulatory compliance goals.

Saleh et al. (2024) reinforce this picture through a broader systematic literature review of 66 papers on CI/CD security in cloud environments, cataloguing widely used tools such as SonarQube and container registries alongside orchestration platforms like GitHub Actions. Their review highlights that while individual scanning tools are mature, the surrounding tooling for aggregating and interpreting their combined output is comparatively underdeveloped — a gap that is directly relevant to a project whose purpose is to consolidate exactly this kind of fragmented output into a single interface.

4. Challenges in DevSecOps Adoption

Despite widespread interest in DevSecOps, the literature consistently identifies significant adoption barriers. Sinan et al. (2025) conducted a systematic literature review specifically focused on security controls in DevSecOps and catalogued 19 distinct challenges alongside 18 proposed solutions drawn from the existing literature. Among the most cited challenges are high false-positive rates from automated scanning tools, difficulty achieving interoperability between disparate security tools, and the scalability limitations of manual review processes as environments grow more complex.

Notably, Sinan et al. (2025) found that a large share of proposed solutions center on automation and tighter tool integration, yet empirical validation of these solutions across real organizational settings remains sparse. This gap between what has been proposed conceptually and what has been evaluated in practice underscores the practical value of building and testing an integrated telemetry portal such as the one proposed for P030, since it would provide a concrete, evaluable instance of the consolidation these studies call for.

5. Unified Dashboards and Visualization for Vulnerability Management

A separate but closely related stream of research addresses how security data, once collected, should be visualized to support decision-making. Manatova, Kouper, and Samtani (2022) designed a vulnerability management dashboard through an iterative, interview-driven process with practicing security analysts. Their work found that analysts routinely struggle to aggregate information from multiple vulnerability scanners, review trends over time, and compare current findings against historical baselines, often resorting to manual review or ad hoc spreadsheet work in the absence of adequate tooling. Their resulting dashboard design prioritized vulnerability aggregation, prioritization by age and severity, and trend visualization — the same functional categories reflected in the summary cards, severity breakdown, and trend charts planned for the P030 dashboard.

Industry practice mirrors these academic findings. Vendors such as Tenable and SecPod market "unified dashboard" products explicitly to solve the problem of security teams working across multiple siloed tools, arguing that centralizing vulnerability data into one interface improves both response time and organizational visibility into overall security posture. While these industry sources are not peer-reviewed research, they corroborate the same underlying need identified in the academic literature: fragmented security tooling creates a visibility gap that a consolidated, real-time interface is well positioned to close.

6. Research Gap and Positioning of the Proposed System

Taken together, the reviewed literature establishes three points relevant to this project. First, DevSecOps as a practice is well established conceptually, with strong consensus on the value of shifting security left into the CI/CD pipeline. Second, the individual scanning technologies that generate security findings — SAST, DAST, and SCA — are mature and well documented, but the literature repeatedly notes that the tools which aggregate and present their combined output lag behind. Third, dashboard design research shows that security analysts benefit measurably from centralized, real-time visualizations, yet purpose-built academic evaluations of such dashboards remain limited in number and scope.

The P030 Unified DevSecOps Telemetry Portal is positioned directly within this gap. Rather than proposing a new scanning technique or a new category of vulnerability detection, the project addresses the consolidation and visualization problem that the literature identifies as underserved: aggregating security scan results and CI/CD pipeline status from Cyberani's existing toolchain into a single, real-time dashboard. In doing so, the project offers a practical, evaluable

contribution to a problem that is well documented in the literature but comparatively under-addressed in existing tooling.

7. Conclusion

This review has traced the conceptual foundations of DevSecOps, the technical role of SAST, DAST, and SCA within CI/CD pipelines, the persistent organizational and technical challenges in DevSecOps adoption, and the research on dashboard design for vulnerability management. Across these strands, a consistent gap emerges: security tooling produces valuable, timely data, but organizations lack accessible, unified interfaces to make sense of it. The Unified DevSecOps Telemetry Portal directly targets this gap for Cyberani by Aramco Digital, and the design choices outlined in the project plan — real-time updates, severity-based prioritization, and trend visualization — are grounded in the same functional needs identified across the reviewed studies.

References

- Koneru, N. M. K. (2021). Integrating security into CI/CD pipelines: A DevSecOps approach with SAST, DAST, and SCA tools. *International Journal of Science and Research Archive*, 3(1), 250–265.
<https://doi.org/10.30574/ijrsra.2021.3.1.0080>
- Manatova, D., Kouper, I., & Samtani, S. (2022). Designing a vulnerability management dashboard to enhance security analysts' decision making processes. In *Practice and Experience in Advanced Research Computing (PEARC '22)*. Association for Computing Machinery.
<https://doi.org/10.1145/3491418.3535176>
- Saleh, S. M., Madhavji, N., & Steinbacher, J. (2024). A systematic literature review on continuous integration and deployment (CI/CD) for secure cloud computing. In *Proceedings of the 20th International Conference on Web Information Systems and Technologies (WEBIST)*, 1, 331–341.
<https://doi.org/10.5220/0013018500003825>
- Shanmugam, B., & El-Den, J. (2025). Evolution of DevSecOps and its influence on application security: A systematic literature review. *Technologies*, 13(12), Article 548.
<https://doi.org/10.3390/technologies13120548>
- Sinan, M., Shahin, M., & Gondal, I. (2025). Integrating security controls in DevSecOps: Challenges, solutions, and future research directions. *Journal of Software: Evolution and Process*, 37(6), Article e70029. <https://doi.org/10.1002/smr.70029>
- SecPod. (2024). Effective end-to-end vulnerability management with SanerNow unified dashboard. <https://www.secpod.com/blog/effective-end-to-end-vulnerability-management-with-sanernow-unified-dashboard/>
- Tenable. (2026). Vulnerability management program health dashboard. <https://www.tenable.com/sc-dashboards/vulnerability-management-program-health-dashboard>